

Módulo 2: Vulnerabilidades de Inyección

T06: Command Injection y Path Traversal

Carlos Rodríguez Contreras · GitHub: [karrocon](#)

 *Cuando el servidor ejecuta lo que tú le dices*

Objetivos

- Entender cómo `child_process.exec` con input de usuario crea una vulnerabilidad de OS Command Injection
- Explotar el endpoint de diagnóstico de VulnApp
- Entender Path Traversal y cómo leer `/etc/passwd` a través de la web
- Aplicar validación estricta de input y allowlists como defensa

En construcción

Este topic todavía no tiene slides completas.

Usa las diapositivas maestras (`slides-curso.html`) como referencia del contenido previsto.

Lab T06: Command Injection en diagnóstico

Objetivo: ejecutar comandos del sistema a través del endpoint de diagnóstico

Setup: `cd VulnApp && npm start`

1. Llama a `GET /debug?cmd=ls` y observa la respuesta
2. Prueba `GET /debug?cmd=ls;whoami` para encadenar comandos
3. Abre `src/routes/debug.ts` y aplica una allowlist estricta
4. Verifica que solo comandos permitidos funcionan